control decisions based on the identity of the client. The process of identifying who an API server is talking to is known as *entity authentication*.

> **DEFINITION** ***Entity authentication*** is the process of identifying who requested an API operation to be performed. Although *message authentication* can confirm who originally authored a request, entity authentication additionally requires that the request is *fresh* and has not been replayed. The connection between the two kinds of authentication can be summed up as ***entity authentication = message authentication + freshness***.

In previous chapters, you've relied on TLS or authentication protocols such as OpenID Connect (OIDC, see chapter 7) to ensure freshness, but end-to-end API requests need to ensure this property for themselves. There are three general ways to ensure freshness:

- API requests can include timestamps that indicate when the request was generated. The API server can then reject requests that are too old. This is the weakest form of replay protection because an attacker can still replay requests until they expire. It also requires the client and server to have access to accurate clocks that cannot be influenced by an attacker.
- Requests can include a unique *nonce* (number-used-once). The server remembers these nonces and rejects requests that attempt to reuse one that has already been seen. To reduce the storage requirements on the